

ANTI FRAUD POLICY

With effect from 1st April, 2026

Version 2.0

Serial No.	Heading	Page No.
1)	Preamble	3
2)	Scope and Intent of the Policy	3
3)	Definition and common types of Fraud	4
4)	Cyber or New Age Fraud	5
5)	Examples of Fraud	6
6)	Internal Reporting Of Fraud	7
7)	Fraud Management/Reporting Structure	7
8)	Fraud Risk Management Framework	9
9)	Potential areas of fraud and Red Flag Indicators(RFIs)	19
10)	Framework for reinsurance	22
11)	Fraud Detection	22
12)	Preventive mechanism	22
13)	Escalation mechanism for taking action	22
14)	Co-ordination with Law Enforcement Agencies.	24
15)	Framework for exchange of Information	24
16)	Due Diligence	24
17)	Regular Communication Chanel	25
18)	Whistle Blower Policy	25
19)	Compliance	25
20)	Recovery of fraud losses	25
21)	Custodian of the Policy	26
22)	Report to the Authority	26
23)	Annual Fraud Risk Assessment	26
24)	Review of the Policy	26

1. Preamble:

Fraud has been a problem for the insurance industry from its early days. Since that time the insurance industry has changed considerably. There is an ever-increasing demand to provide excellent service, control claim costs, reduce the life cycle of claims and meet policy-holders legitimate expectations. Within the insurance market, insurers have to respond quickly, and fairly to policy holders and claimants, which is only right. However, it is also imperative that claims are validated properly to ensure that the premium pool which is funded by all policy holders is not depleted by the fraudulent activities of the increasing few.

Fraud occurs whenever a suitable opportunity presents itself. For a business organization it causes avoidable financial losses, loss of good will and image and loss of shareholder confidence among others. All well managed organizations recognize this reality and take steps to deal with it in a proactive manner.

IRDAI vide its notification IRDAI/IID/GDL/MISC/112/10/2025 dated 09.10.2025 called upon insurers and distribution channels to address and manage risks emerging from frauds. The revised Policy incorporates provisions for affinity and complex frauds, alongside regulatory guidelines governing reinsurance-related fraud exposures, to ensure regulatory compliance, protection of policyholder interests, and the maintenance of high standards of integrity and transparency. Hence, it has been revised in light of these new changes.

Keeping the above guideline in view and the overall approach of National Insurance Company Ltd (Company) of following the principles of “Corporate Governance” and implementing “best practices” in all areas proactively, it is absolutely necessary that a proper “Anti-Fraud Policy” is formulated, published appropriately and implemented in the Company.

Hence the corporate “Anti- Fraud Policy” (Policy) has been framed, first in 2013, followed by review in 2015, 2019, 2021, 2022, 2025 and now in FY 2025-26.

2. Scope & Intent:

Any activity with the intention of perpetuating fraud against the Company shall not be tolerated. The sole purpose of the policy is to keep on record and provide directions to the Company for prevention, detection, mitigation, reporting and remedy of fraud. This would be applicable to all the offices of the Company concerted with related operational guidelines/ instructions issued by the Company from time to time. The monitoring and risk management of fraud shall be owned by Chairperson and Managing Directors/Chief Executive Officers (CMD/CEOs), Risk Management Committee and Audit Committee of the Board of the insurer.

The Policy is intended to:

- 1) Enable understanding of “Fraud” and its implications and effects on the entire organization.
- 2) Create a “Fraud Awareness” and “Fraud Prevention” culture in the Company and to send across a message within the Company and to the public at large that fraud is not acceptable and shall not be tolerated.
- 3) Enable prevention and reporting system for pro-active tackling of fraud and make efforts to recover fraud losses.
- 4) Protect policyholder’s interest, safeguard financial stability and maintain public trust
- 5) Encourage Whistle blower complaints
- 6) Closer analysis and audit of claims vulnerable to frauds within a specified range in each LOB
- 7) Use ML Models with frequent data inputs to identify frauds.
- 8) Initiate appropriate action by FMC against the defaulter employee for non-compliance of fraud Risk Management Framework.

3. Definition and Common Types of Fraud:

“Fraud”, in general, is a wilful act committed by an individual(s)/ entity(ies) by deception, misrepresentation, suppression, cheating or any other fraudulent means or illegal means thereby causing wrongful gain(s) to self or any other individual(s) and wrongful loss to the organization.

In insurance, “Fraud” is an act or omission intended to gain dishonest or unlawful advantage for a party committing the fraud or for other related parties. This may for example be caused by means of:

- a) Misappropriating assets
- b) Unauthorized misappropriation of company’s data
- c) Deliberately misrepresenting, concealing, suppressing or not disclosing one or more material facts relevant to the financial decision, transaction or perception of the insurer’s status
- d) Abusing responsibility -a position of trust or a fiduciary relationship

The IRDAI circular referred to above recognizes that insurers typically face prospects of fraud of five main categories namely

- a) Policyholder Fraud and/or Claims Fraud
- b) Distribution Channel Fraud
- c) Internal Fraud
- d) External Fraud
- e) Affinity Fraud or Complex Fraud

A) Policyholder Fraud and/or Claims Fraud:

Fraud against the Company in the purchase and/or execution of an insurance product including fraud at the time of making a claim. These types of frauds include but not limited to:-

- a) Exaggerating damages/losses
- b) Staging the occurrence of accidents
- c) Reporting and claiming fictitious damages/losses
- d) Medical claims fraud
- e) Fraudulent death claims

B) Distribution Channel Fraud:

Fraud perpetrated by an insurance agents/ Insurance Brokers/Corporate Agents, bancassurance partner etc. against the company and/or policyholders.

Entities falling under the purview of e-commerce as defined in relevant laws/regulations shall be guided by the provisions made under this Policy.

These types of frauds include but not limited to:-

- a) Premium diversion-Distribution channel takes the premium from the purchaser and does not pass it to the insurer
- b) Inflates the premium- Passing on the correct amount to the insurer and keeping the difference
- c) Non-disclosure or misrepresentation of the risk to reduce premium

C) Internal Fraud:

Fraud/misappropriation against the Company by its Directors, Managers and/or any other Officers or Staff members (by whatever name called). These types of fraud include but not limited to:-

- a) Misappropriating funds
- b) Fraudulent financial reporting
- c) Stealing cheques
- d) Inflating expenses claims/over-billing
- e) Forging signatures.

D) External Fraud:

External fraud is the risk of unexpected financial, material or reputational loss as the result of fraudulent action of persons, external to the National Insurance Company Ltd. External fraud typically refers to frauds committed by third parties such as service provider and vendors. These types of frauds include but not limited to:-

- a) Premium siphoning and embezzlement
- b) Unauthorized access to insurer's resources
- c) Inflating repair costs or billing for services not rendered after an insured event
- d) Performing unnecessary medical procedures to bill insurers
- e) Selling fake insurance policies or coverage
- f) Recruitment related fraud

E) Affinity Fraud or Complex Fraud: Fraud involving collusion among one or more fraud perpetrators in the above categories.

4. Cyber or New Age Fraud:

Cyber / New Age Fraud refers to fraudulent activities (such as phishing, hacking, social engineering and such methods with intention of unlawful financial gain etc.) that are intended to gain access to personal digital information, company sensitive data, stealing/ transferring monies and or tampering with digital records of financial and other assets etc. using digital platforms, technology, or the internet. This type of fraud is becoming a significant concern for the insurance sector, as it involves a range of personal and financial information that insurers and distribution channels hold about their policyholders/ claimants.

Cyber or New Age Fraud can lead to:

- a) **Loss of Confidential Data:** Personally identifiable information collected and stored by the company, such as KYC details, financial details, and medical records.
- b) **Sensitive Information being compromised:** Insurers may collect sensitive business information such as medical records that could be valuable to other corporates / foreign spies/ external entities. In the case of certain lines such as cyber insurance products or a kidnap & ransom insurance, the company may possess information about a policyholder's network security controls, head or key executives of the client organization in digital form and other cyber resilience information that could be valuable and could harm intellectual property rights of either party.
- c) **Disruption of Operations:** Cyber-attacks can result in disruption to normal business operation including emails, telephone directories, and voice mails amongst business records such as contract templates.
- d) **Loss of Trust:** The foundation of insurance business is policyholder's trust. Trust that the information collected by insurers will be protected, and trust that claims will be paid out in a timely way when appropriate. If an insurer were to suffer a cyber-security incident that rendered it unable to make timely claims payments that trust may also be shaken. The reputational risk could extend to the sector as a whole.

In order to prevent such frauds, the company shall:

- a) **Cyber Risk Mitigation:** - For Prevention of cyber risks, the company shall have in place a comprehensive Cyber or New Age Risk Management Policy including SOPs and robust Cybersecurity Framework to improve our cybersecurity practices, ensure data protection and ensure compliance with regulatory requirements. Overall responsibilities for prevention and taking remedial measures shall lie with the CISO. The company shall utilize a team with relevant risk and technological expertise to manage cyber

fraud risks across various insurance business lines.

Company should have comprehensive cyber risk insurance policies, covering first-party and third-party risks. This policy should cover damages caused by cyber assaults and costs associated with data recovery, business interruption, and legal obligations.

b) Creation of Incident Database: Incident database is a record-keeping system where all fraud-related incidents are documented in organization which helps in quick fraud risk identification, detection, prevention and mitigation.

It can be reasonably stated that the company can expect that a fraud could be perpetrated against it by any of the following acting alone or in combination with another:

- a) Employee(s), Ex-employee(s)
- b) Persons engaged for work or assignment on temporary/ad-hoc/contract/daily wage basis and/or their individual employees/representatives
- c) Advisors(s), consultants and similar providers of professional expertise including surveyors/valuers / loss adjusters, lawyers, investigators and/ or their individual employees/representatives
- d) Vendors, suppliers of any goods or services to the Company (including IT hardware/software suppliers and support and maintenance providers)
- e) Third Party Administrators (TPAs) and/or their individual employees/representatives
- f) Customers/clients of the company and/or their individual employees/representatives
- g) Agents and/or their individual employees/representatives
- h) Brokers and/or their individual employees/representatives.
- i) MISP/ IMFs/ Web Aggregators/ Marketing agencies/ any other intermediary/Service Provider/ Representatives.

5. Examples of Fraud:

The following are some of the typical examples of fraud that may be expected. It may be noted that this list is merely illustrative and is not exhaustive and it may not be treated as complete for the purpose of this policy:

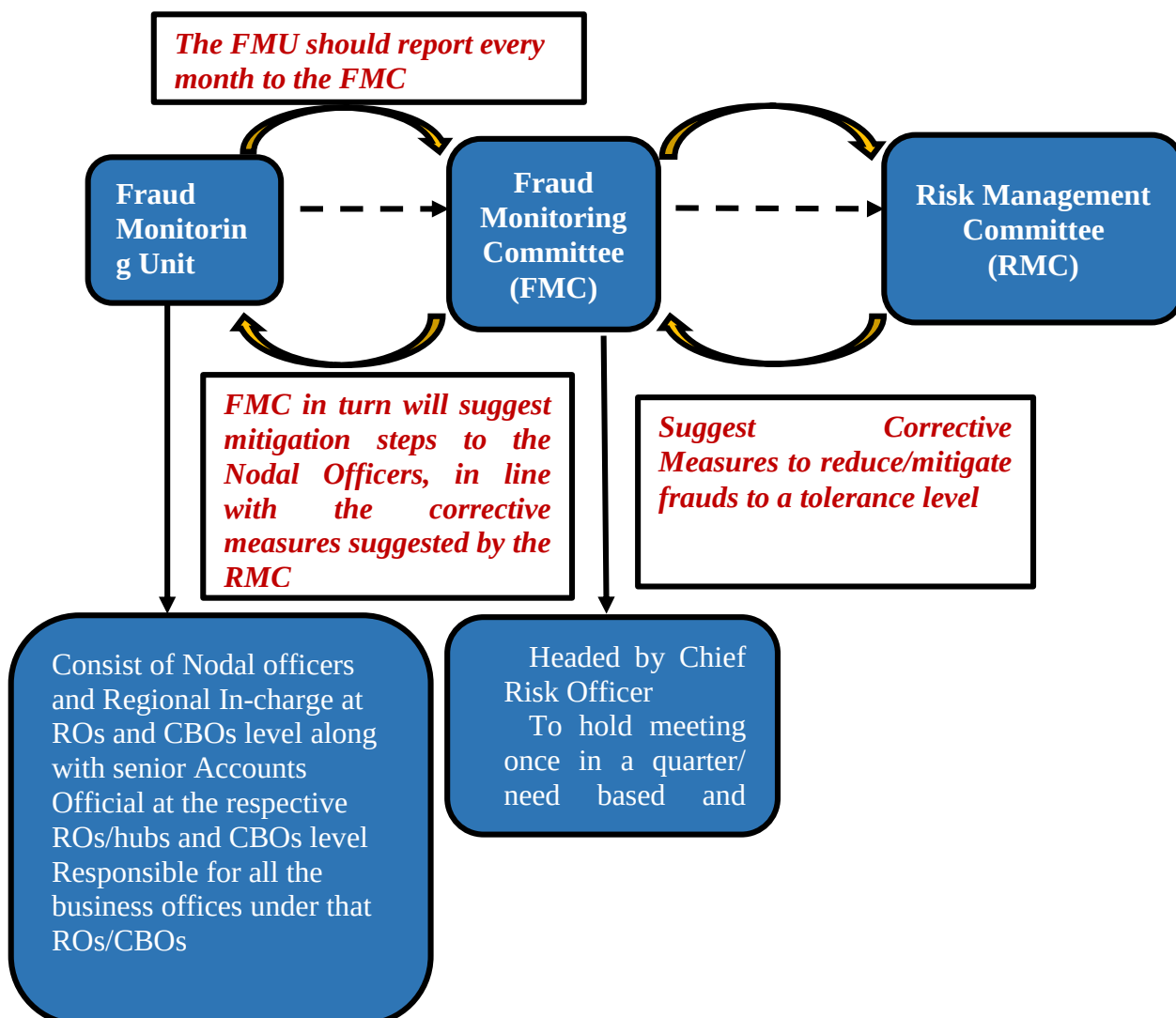
- a. Willful suppression of facts/deception in matters of appointment, in submission of reports of any nature to the company, in any recommendations or making such recommendations as a result of which a wrongful gain is made to any person/organization/entity and/or a wrongful loss is caused to the company or the public exchequer
- b. Forgery or unauthorized alteration of any document (including certificate of insurance, insurance policy/ endorsement/ cover note/ declaration etc.) or correspondence or account belonging to the company
- c. Forgery or unauthorized alteration of cheques, bank drafts or any other financial instruments
- d. Misappropriation of funds, securities, supplies or other assets by fraudulent means
- e. Falsifying records, removing documents/papers/notes from files and/or replacing them
- f. Making fraudulent/false notes in official records of the company
- g. Utilizing company's funds for the purposes for which the said fund are not intended
- h. Effecting major material deviation from standard laid down tendering procedures or norms without clear written authorizations and "speaking orders"
- i. Vendor Fraud (e.g. consideration including the receipt of gifts or accepting or seeking anything from contractors, vendors or persons providing services/materials)
- j. Electronic Fraud and/or illegal hacking, unauthorized or illegal manipulation of information technology networks or operating systems
- k. Tax evasion
- l. Destruction, removal or inappropriate use of records, furniture, fixtures and equipment of the company
- m. Sales or assignment of fictitious or misrepresented assets

n. Any other act that falls under definition of “Fraud”

6. Internal Reporting of Fraud:

- It is the bounden duty of every employee of the company to provide information to the management which is within his/her knowledge about any fraud or potential fraud. They will be guided by the principle of “Passivity is not an option”.
- Every instance of attempted fraud or detected actual fraud (regardless of whether it has caused actual financial loss to the company at that juncture or not) shall be reported without delay by the affected department/operational unit/any person having knowledge, to the overseeing office/department/executive. Where the fraud involves or is reasonably suspected to involve an employee of the company, it shall also be reported to the Vigilance Department at Regional Office (RO) or Head Office (HO) as applicable.
- Every such instance of fraud shall also be reported to the Fraud Monitoring Committee (FMC) by the department/operational unit.
- The Board shall encourage anyone having reasonable suspicion to report to appropriate authority and no employee shall suffer in any way as a result of reporting reasonably held suspicion. For these purposes “reasonably held suspicions” shall mean any suspicions other than those which are shown to be raised maliciously and found to be groundless.

7. Fraud Management/Reporting Structure:



7.1. Constitution of Fraud Monitoring Committee (FMC) and its functions:

- Fraud is a critical risk facing an enterprise that needs to be managed/ controlled/mitigated by the Company in an organized way. To achieve this end, a dedicated Fraud Monitoring Committee(FMC) as a part of Enterprise Risk Management (ERM) Department has been set up in the company.
- Fraud Monitoring Committee (FMC) shall be headed by the Chief Risk Officer and also consist of Deputy General Manager (DGM) Accounts (Head office) & Officers preferably of the rank of Scale V from concerned Line of Business(LOB) /Departments at Head Office.
- The FMC may establish sub-committees or task forces for its effective functioning.
- FMC shall meet once in a quarter (or as and when required) to discuss the matters relating to Fraud Prevention and monitoring.

The function of FMC is to:

- a) Recommend and regularly update, based on experiences, appropriate measures on fraud risk management to various functions.
- b) Oversee prompt responses to instances or suspicions of fraud.
- c) Maintain all relevant details pertaining to each instance of fraud.
- d) Facilitate collaboration with industry peers / bodies, law enforcement agencies and regulatory bodies to pursue cases of fraud and share information / intelligence on known fraud schemes and perpetrators.
- e) Conduct an Annual Comprehensive Fraud Risk Assessment to identify potential vulnerabilities across business lines and activities for fraud, using past experiences, emerging trends & Red Flag Indicators (RFIs), etc.
- f) Identify areas for improvement and adaptation of the Fraud Risk Management Framework.
- g) Submit report of the Annual Comprehensive Fraud Risk Assessment before RMC through CRO, based on the data of fraud reported.

7.2. Fraud Monitoring Unit (FMU):

Nodal officers and Regional In-charges at their respective ROs and CBOs level along with senior Accounts Official at the respective ROs/hubs and CBOs level, shall constitute an independent Fraud Monitoring Unit (FMU), separate from internal audit, which will support FMC in discharging its functions and shall be responsible for implementing measures for fraud deterrence, prevention, detection, monitoring, investigation, reporting and providing remedy at their respective ROs and CBOs level.

The functions of the FMU, in addition to supporting FMC, shall inter alia include:

- a) Effective implementation of measures suggested by FMC.
- b) Monitoring insurance claims, policy applications, and verifying transactions as well as information through RFIs (Red Flag Indicators) and detailed investigations.
- c) Investigations along with evidence gathering and collaboration with relevant departments, ensuring conflicts of interest are identified and avoided.
- d) Timely reporting of identified fraud cases to FMC and maintaining transactional-wise details of each and every fraud including action taken.
- e) Coordinate with industry peers/bodies, law enforcement agencies (LEAs) and regulatory bodies to pursue cases of fraud and share information/intelligence on known fraud schemes and perpetrators.

7.3. Nomination of Nodal Officer and Role:

- A senior level officer, preferably Scale IV, is nominated at each RO to receive information from various operating offices and take necessary action. The Nodal Officers should report to the FMC at Head Office of the company.

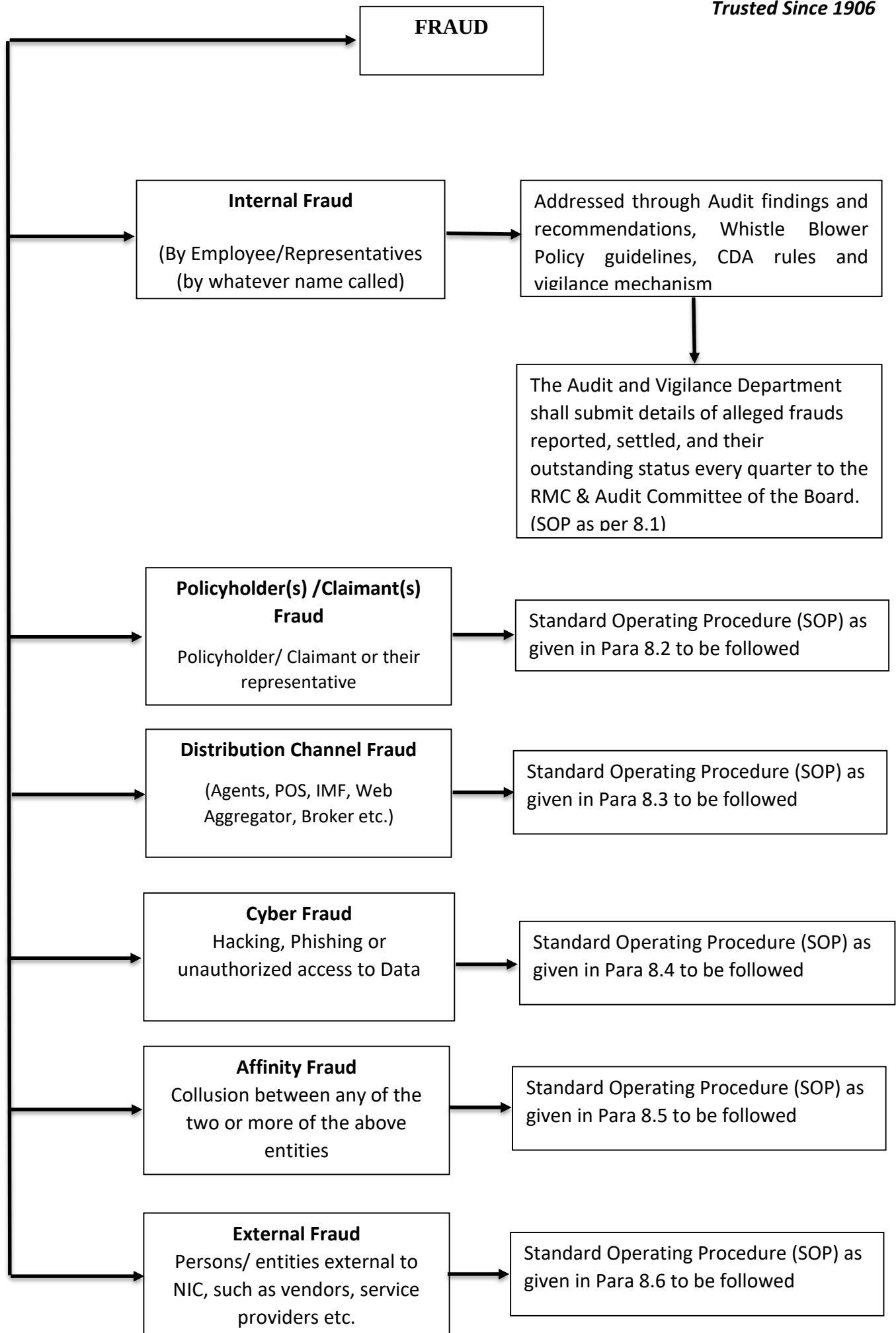
- The FMU shall implement the modules suggested by FMC to create awareness among the employees and officers in fraud detection and mitigation.
- The awareness modules suggested by the FMC for employees and officers including distribution channel, service providers & intermediaries in fraud detection and mitigation shall be implemented by the Nodal Officers in their respective ROs/CBOs and by the ERM Department at the Head Office.
- Nodal Officer to coordinate with Operating Offices under its jurisdiction for implementing SOPs and reporting of frauds and maintaining data repository for fraud claims.
- Any outsider(s) or employee(s) who is in the knowledge or come across any fraud/ fraudulent practices committed by an intermediary or policyholder or employee can notify the same to Nodal Officer at RO/CBO or FMC at HO directly, if he/she deems it necessary. If the issue has already been investigated by the operating offices, then such investigation report shall also be forwarded to the Nodal Officer of the respective RO/CBO.
- The Nodal Officer of the respective RO/CBO is authorized to take original records from operating offices/ take copies/ emails or any other communication as he may decide to be required for the purpose of establishing the fraud committed.
- The Nodal Officer in concurrence with FMU at their respective RO/CBO, with the assistance of involved operating office, is authorized to initiate action by law enforcing agencies including the police authorities against the persons who have been identified to have committed the fraud.

7.4. Organizational Structure:

- The FMU shall report to the FMC on a monthly basis, providing details of all fraud cases reported and pending within the respective offices. In the event that no fraud cases are reported during a month, a 'Nil' report must be submitted.(point included for importance of reporting fraud on monthly basis)
- FMC should submit quarterly detailed reports of fraud cases to Risk Management Committee (RMC) of the Board. It shall also report to Audit Committee and RMC in case of Internal Fraud.
- RMC will suggest corrective measures to FMC for eliminating fraud and it may further consult for corrective measures or may seek advice from GM IT, Chief Compliance Officer, GM Audit, ERM Department-Head Office, Chief Financial Officer (CFO) or any other officer, as and when required, based on the nature of Frauds.
- RMC should review the reports submitted by FMC, recommend system checks and alert the Audit and Vigilance Department.
- FMC in turn will suggest mitigation steps to the Fraud Monitoring Unit (FMU), in line with the corrective measures suggested by RMC that is to be implemented and documented.

8. Fraud Risk Management Framework

The Company shall maintain a robust Fraud Risk Management Framework (FRMF) designed to proactively identify, assess, mitigate, and monitor fraud risks across all business functions. The Risk Management Committee (RMC) shall be responsible for effective implementation and oversight of the fraud risk management framework. The framework is built upon the principle of Zero Tolerance toward fraud. The fraud risk management framework shall be specific to the insurer's business considering the nature of business, size, risk profile, overall business strategy, products, distributions channels, technology infrastructure, and any other applicable parameter including various activities. The IRDA in its 2025 Regulation has mentioned five categories of fraud as a result the Fraud Risk Management Framework has been modified to include this classification:



8.1. Mechanism to deal with Internal Fraud:

- a) The Company has also an Internal Audit and Inspection Department (IA &ID) that audits transactions and accounts which on occasion reveal commission of frauds.
- b) The Company already has a well-defined system and procedure for tackling internal frauds i.e. frauds committed by company's own employees, through the Vigilance Department. The Vigilance Department itself has the avowed intent to be proactive in implementing "Preventive Vigilance" by means of making system studies, anticipating fraud prone areas, spreading awareness and sensitizing drives, conducting surprise checks and so on. It is also expressly tasked with investigation of suspected frauds by own employees acting by themselves or in concert with outside elements and bringing established cases of fraud (with evidence) to suitable conclusion by disciplinary proceedings or any other appropriate punitive measure. The Department functions in the light of the Conduct, Discipline and Appeal Rules (CDA Rules).
- c) The function or intent of the Fraud Monitoring Committee (FMC) is not to take over, duplicate or even overlap the functions of these two departments but to act in co-ordination with them. By itself, the FMC shall also pay particular attention to studying and monitoring fraud emanating from policy holders/customers as well as from intermediaries. The FMC shall:
 - I. Co-operate actively with the Vigilance, and IA &ID departments to respond to fraud allegations
 - II. Collect fraud data from these departments and from the operational units of the Company
 - III. Analyze these
 - IV. Identify Risk Indicators
 - V. Suggest effective control mechanism
 - VI. Report periodically to the Risk Management Committee of the Board
- d) However, in cases of frauds involving more than one entity, one of which is an internal entity, the SOP shall be as per the Affinity or Complex Fraud.

8.2. SOP for alleged frauds by Policyholders/ Claimants

STEP 1: Recording

Timeline: Immediate

The Fraud needs to be recorded by the Office. This would include details obtained, source from which information received, documents received thereof, and other material facts.

STEP 2: Internal Verification

Timeline: Initiation within 3 days

Based on information and documents above, to ascertain whether it is policy-related or claim related. Office to verify the existence of policy, declarations in proposals, whether any mis-declaration /suppression of material information has been resorted to in commission of the fraud. Also if claim related, whether reported, it's present status etc. It should be initiated within 3 days of receiving the complaint.

STEP 3: Investigation

Timeline: Report submission within 15 days

Decide on Investigation agency, whether by Office, or through professional investigator. Specify terms of reference under which investigation is to be carried out. Timeline for report submission should be as early as possible but maximum 15 days, unless there are extenuating circumstances for delay, which should be recorded. Report should highlight whether any collusion exists between Insured and other entities.

STEP 4: Action on finding

Timeline: Within 30 days of receipt of report

If found established, action to be taken against the policyholder. Action would involve cancellation of policy without refund, and serving notice thereof. Wherever required, recovery proceedings to be initiated. Decision needs to be taken in conjunction with RO Nodal officer whether, and what, further action (Legal/Criminal) needs to be taken within 30 days depending on gravity and nature of fraud.

STEP 5: Reporting by Offices

Timeline: Immediate to Nodal Officer, and Monthly on given template

Offices to intimate frauds to Nodal Officer as and when they occur, and to keep Nodal Officer informed at all stages. Monthly report of such frauds to be communicated to Nodal Officer, giving status. The reporting is to be done on a standard template.

STEP 6: Reporting by Nodal Officer

Timeline: by 7th of every succeeding month

Nodal Officer will compile frauds reported by various offices under their jurisdiction, and summarize the same. The detailed Template of all reported frauds with resolution/status to be communicated to FMC at HO in consultation with FMU.

STEP 7: Review and action by FMC

Timeline: meeting every month

FMC shall review the reports submitted by each Nodal Officer for the month. They will also examine the action taken at the ground level (Operating Office/RO), and decide on whether further action, other than those initiated, need to be taken.

STEP 8: Reporting to RMC and Internal Audit Committee

Timeline: Quarterly basis

FMC to collate the reports and summarize each of the cases for information to the Risk Management Committee and Internal Audit Committee through the CRO.

ERM Review:

The directions of the RMC/Board to be recorded for compliance, and report thereof on Action Taken, to be placed before the RMC in subsequent meeting(s).

All the frauds (other than internal frauds), reported to HO, need to be analyzed by the ERM Team, with the assistance of the FMC. Necessary checks to prevent occurrences are to be identified, and put in place. As a part of information sharing, details of established fraudsters/ repeated offenders to be shared on Fraud Monitoring Portal of GI Council and also to all our offices. Recommended system checks to be intimated to IT for building into the program. The Audit and Vigilance Departments shall be alerted to conduct inspections / special audits to verify/ ascertain the veracity of the fraud allegations

8.3. SOP For Frauds by Distribution Channels (individual Agents, Corporate Agents, Brokers, POS, IMF, Web Aggregators etc.):

STEP 1: Identification & Recording

Timeline: Immediate

Identify the entity allegedly having committed fraud and this is to be recorded by the Office. This would include details obtained, source from which information received, documents received thereof, and other material facts.

STEP 2: Internal Verification

Timeline: Initiation within 3 days

Verify the stage at which alleged fraud has been initiated. Prima facie involvement of agent / broker / intermediary would require review of their portfolio within 3 days, so this needs to be flagged, pending final investigation. Prima facie involvement of surveyor / advocate / service provider would require suspension of work, pending final investigation.

STEP 3: Investigation

Timeline: Report Submission within 15 days

Decide who shall conduct the investigation whether by Office, or through professional investigator. Specify terms of reference under which investigation is to be carried out. Timeline for report submission should be as early as possible but maximum 15 days, unless there are extenuating circumstances for delay, which should be recorded. Report should highlight whether any collusion between Intermediary and other entities.

STEP 4: Action on Finding

Timeline: Within 30 days of receipt of report

If fraud is found established, action to be taken against the Intermediary would involve the following, which is indicative, and not exhaustive:

- a) For Individual Agents: Depending on nature and severity of offence, the Operating Office can recommend suggested action to the FMU. This could involve suspension/ temporary blocking of business code as per terms of the contract. Information should be disseminated to all our offices also so that the agent is not entertained elsewhere. HO Marketing to be kept abreast of action taken against individual Agents.

The concerned Technical department at HO shall, then act immediately as per the directives of this Committee.

- b) For Brokers/Corporate Agents/Other Intermediaries: The process will be similar to (ii) above. The Committee in this case will include DGM (Marketing) also. The Committee shall decide on the action to be taken, both at Company level and for reporting to IRDAI.

STEPS 5, 6, 7 (Reporting Procedure), and ERM REVIEW:

Similar to what has been outlined in SOP for Policy Holder Fraud mentioned above.

8.4 SOP for Cyber Fraud:

STEP 1: Recording

Timeline: Immediate

Any attempt of or suspected of hacking, phishing or unauthorized access to data/ computer resources shall be reported to HOIT Security team immediately/ as soon as it comes to the notice of any employee. Any attempted/ actual cyber frauds reported to Nodal Officers shall be forwarded to the HOIT Security Team immediately. Also, HOIT Security Team shall continuously monitor any such attempts and take prompt action. The incidence of cyber breach should be recorded by the IT Security Department. This would include details obtained, source from which information received, documents/ materials/ any other materials or evidences received thereof, and other material facts.

Upon receipt of a cyber-fraud, the HO-IT Security Team / Security Operations Centre (SOC) shall work with the Cyber Crisis Management Team (CCMT) and ERM to:

1. Register the incident in the Cyber Fraud Incident Register maintained by the IT Department.
2. Record:
 - Source of information
 - Time of incident detection
 - Nature of suspected fraud
 - Affected systems
 - Potential financial impact
 - Available evidence/logs.
3. Preserve digital evidence including:
 - system logs
 - network logs
 - authentication records
 - transaction records
 - Email headers or phishing artifacts.
4. Notify:
 - CISO
 - ERM Department
 - Concerned business unit
 - Legal Department, if required.

SOC shall continuously monitor and analyze indicators of compromise to prevent escalation.

HOIT Security Team shall make efforts to put in place an automated cyber fraud detection mechanism.

Physical fraud without any cyber element is addressed under the Company's Physical Fraud SOP. However, hybrid fraud (physical + cyber) has been addressed under the Affinity Frauds.

STEP 2: Containment

Timeline: immediate

The HO-IT Security Team / SOC in conjunction with Cyber Crisis Management Team (CCMT) shall initiate containment actions to prevent further damage.

Possible actions include:

- Isolation of affected systems
- Blocking malicious IP addresses or domains
- Disabling compromised accounts
- Revoking access credentials
- Suspending suspicious transactions
- Blocking compromised APIs or application modules

If financial transactions are involved:

- Accounts / Funds Department shall be informed immediately
- Bank advisory may be issued for freezing suspicious transactions

SOC shall coordinate with CCMT (Infrastructure, Application and Network teams) to implement containment actions.

STEP 3: Verification and Investigation

Timeline: Initiation within 3 days

Based on information/ digital documents/ system logs/ other relevant materials received, HOIT Security Team shall verify the information and ascertain whether such breach has indeed been attempted/ occurred.

Timeline: Initiation within 24 hours

HO-IT Security Team / SOC in conjunction with Cyber Crisis Management Team (CCMT) shall conduct a technical investigation to determine:

- Whether the incident is a confirmed cyber fraud
- Method of compromise
- Systems affected
- Data exposure
- Financial implications
- Attack origin and threat actor indicators

Investigation may include:

- Log analysis
- Network traffic analysis
- Endpoint forensic examination
- Email header analysis
- Authentication logs
- Transaction verification.

Where necessary, cyber forensic experts may be engaged. HOIT shall inform the CISO of the outcomes of the investigation.

STEP 4: Findings of the Investigation and Categorization

Timeline: Initiation within 3 days

Cyber fraud incidents may fall into the following categories:

1. Policy Fraud
2. Claims Fraud
3. Payment / Financial Fraud
4. Distribution Channel Fraud
5. Data Breach / Data Exfiltration
6. Social Engineering / Phishing Fraud
7. Insider Cyber Fraud
8. Hybrid Fraud (Cyber + Physical)

STEP 5: Decision and Action on findings

Timeline: Within 7 days

Once the fraud has been established action such as resetting of compromised credentials should be undertaken by the HOIT Security Team. For actions on retrieval of diverted funds/ freezing of funds or accounts advisory should be sent to the Accounts/ Funds Department for taking up with the relevant bank accounts. For action on fraud perpetrators the steps given in escalation mechanism may be followed. For cyber-attack on IT infrastructure etc. existing SOP in place shall be followed.

STEP 6: Recovery and Closure

Timeline: Within 15 days

Finally, affected systems may be restored from clean backups integrity verified before reconnection. Any regulatory report required may be filed. Any requirement of filing of FIR / complaint with Cyber Crime Cell etc. shall be advised by the CISO.

The CISO shall be kept informed of the developments at every stage.

STEP 7: Reporting and review by FMC

Timeline: in the next FMC Meeting

Upon closure of investigation:

HO-IT Security Team shall prepare a Cyber Fraud Investigation Report including:

- Incident summary
- Attack methodology
- Systems affected
- Financial impact
- Root cause analysis
- Corrective actions implemented
- Preventive recommendations

Details of the cyber incident, findings, action taken and post incident report requiring plugging of any systemic loopholes must be reported to the ERM Department within 7 days of finalization of such report. ERM shall place the findings before the FMC for their review and recommendation. The FMC review in case of cyber frauds shall include the CISO in addition to the regular members. Onward submission to the Risk Management Committee in its next Meeting.

STEP 8: Presentation to the RMC

Timeline: RMC Meeting

Each case of cyber frauds as reviewed by FMC shall be placed before the RMC for its guidance/ instruction.

8.5 SOP for Affinity Frauds:

IRDAI in its new regulation on Fraud Framework has introduced a new category called affinity fraud or complex frauds. IRDA has defined it as fraud involving collusion among one or more fraud perpetrators in the above categories. The SOP for affinity frauds shall be dealt as per the respective fraud categories.

STEP 1: Identification and Recording

Timeline: Immediate

Identify the entities allegedly having committed fraud and this is to be recorded by the Office/ Nodal Officer. This would include details obtained, source from which information received, documents received thereof, and other material facts. On the basis of the materials on record, a terms of reference for investigation may be formulated for the next course of action.

STEP 2: Verification and Investigation

Timeline: Initiation within 15-30 days

The Investigation may be conducted by the Nodal Officer, an Investigation Committee appointed by the FMU and/ or involving professional investigator(s), depending upon the extent, severity and complexity.

The facts of the allegation should be verified in light of the documents/ materials on record. In cases involving external entities, external/ professional investigator may have to appoint to map the entire network of perpetrators. These frauds can be more organized, designed to bypass internal controls that would otherwise catch a single-actor fraud. Perpetrators can include employees, ex-employees, surveyors, advocates, TPAs, and various intermediaries acting in concert. Such frauds can be in the form of fraud rings and apply complex methodologies. Investigation must take into account these factors. In certain cases involving company employee, close coordination with IA& ID and/ or vigilance may be required to arrive at a conclusion. Nodal Officers are authorized to take original records, copies of emails, and other communications required to establish the link between the parties.

Investigation report must bring out the number of actors involved, extent of involvement of each actor, the collusion and also map the links/ nexus between the actors to build the whole picture and methodologies used in the fraud. However, after the investigation the report shall cover any collusion between the multiple entities involved in the fraud. If collusion is not established or any entity has to be absolved of the charges, it must be clearly recommended in the report along with the reasoning. Also, if any entity is absolved of the charges due to lack of evidence or insufficient evidence the same may also be mentioned.

In cases where the investigation is not likely to be completed within the given timeline, an interim report may be submitted in 15 days, mentioning the need for further time along with reasons. Investigation may be regularly be monitored by the Regional Incharge/ Department Incharge.

STEP 3: Decision and Action on findings

Timeline: Within 7 days

The findings of the Report in such cases shall be placed before the FMU/ FMC (For cases reported at the HO level) for a complete evaluation of the extent of the severity in terms of number of policies involved and the amount involved. FMU/ FMC shall then recommend suitable action for reach actors/ perpetrators. The action shall independently apply to the perpetrating entities.

STEP 4: Reporting and review by FMC

Timeline: in the next FMC Meeting

Details of the cyber incident, findings, action taken and post incident report requiring plugging of any systemic loopholes must be reported to the ERM Department within 7 days of finalization of such report. ERM shall place the findings before the FMC for their review and recommendation. The FMC review in case of cyber frauds shall include the CISO in addition to the regular members. Onward submission to the Risk Management Committee in its next Meeting.

STEP 5: Presentation to the RMC

Timeline: RMC Meeting

The brief account of the frauds as reviewed by FMC shall be placed before the RMC for its guidance/ instruction.

8.6 SOP for External Frauds:

IRDA in its new Regulations has notified a category of fraud as external fraud. This *inter alia* shall cover vendors, service providers such as TPAs, Advocates, Surveyors, Hospitals, Motor Garages etc. the steps for SOP shall be as follows:

STEP 1: Identification & Recording

Identify the entity allegedly having committed fraud and this is to be recorded by the Office/ Nodal Officer. This would include details obtained, source from which information received, documents received thereof, and other material facts.

STEP 2: Internal Verification

Timeline: Initiation within 3 days

Verify the stage at which alleged fraud has been initiated. Prima facie involvement of the external entity viz., surveyor / advocate / service provider would require suspension of allotment of further work, pending final investigation.

STEP 3: Investigation

Timeline: Report Submission within 15 days

Decide who shall conduct the investigation whether by Office, or through professional investigator. Specify terms of reference under which investigation is to be carried out. Timeline for report submission should be as early as possible but maximum 15 days, unless there are extenuating circumstances for delay, which should be recorded. Report should highlight whether any collusion between Intermediary and other entities.

STEP 4: Action on Finding

Timeline: Within 30 days of receipt of report

If fraud is found established, action to be taken against the Intermediary would involve the following, which is indicative, and not exhaustive:

- a) For Surveyors/TPAs: If charges are proven beyond reasonable doubt, the suspension of work shall continue at the local level for surveyors and Advocates. Since the engagement of TPAs is through a different process, necessary caution letters should be sent to the TPA for explanation and replies should be recorded, and HO Health be kept informed. Allocation of GMC business may be suspended at local level after approval from HO Health Tech. Dept. For the instances which merit stringent action, and there is a violation of the Regulatory Code of Conduct, FMU shall notify FMC as well as the concerned Technical department at HO. Such cases will be put up by FMC, within 7 working days, to a High-Level Committee comprising: (a) DGM (Concerned Tech Department), (b) DGM (ERM/Anti-Fraud) and (c) Chief Compliance Officer.

Since Surveyors & TPAs are IRDAI certified, the decision to inform IRDAI shall be taken by the said Committee. For such cases, the Committee may also recommend for All-India De-Empanelment in terms of Surveyor Management Policy/ TPA Regulations and SLAs. Also whether, and what, further Legal/Criminal Action is suggested. The Committee shall submit its directives within 7 days of receiving the fraud report.

- b) For Service Providers: In case of Hospitals, the Health department needs to act as per provisions/guidelines for dealing with Fraudulent Service Providers, as given in the Service Level Agreements with Third Party Administrators.

Similarly Motor Tech Department will address the Garages issue. For the Motor Garages, first garages should be red flagged. Hubs may perform closer scrutiny of claims received from these garages. Decision on suspension of work/ blacklisting of the garages may be taken by the FMU and HO Motor OD Dep't/ SAM-D may be kept informed.

STEP 5: Reporting and review by FMC

Timeline: in the next FMC Meeting

Details of the external fraud cases shall be reviewed by the FMC in its next meeting. Post incident observation regarding plugging of any systemic loopholes must be decided. ERM shall place the findings before the FMC for their review and recommendation.

9. Potential areas of fraud and Red Flag Indicators (RFIs):

Red Flag Indicator or RFI means a possible warning sign that points to a potential fraud and may require further investigation or analysis of a fact, event, statement, or claim, either alone or with other indicators. The company shall have a Real Time Fraud Monitoring System in place which shall be monitored by the Fraud Risk Management Committee.

One of the major areas of potential fraud is through intermediaries who have access to the company system and can exploit it to conduct a fraud in any line of business either with the company or policyholder or both. Some of the major types of frauds conducted by intermediaries are as follows-

S. No	Nature of Fraud	Identification Measures/ RFIs	Mitigation/Prevention Measures/Action
1	Non-Submission of premium to office	Insured complaints and allegations through letters and mails on faf@nic.co.in , or any other means.	Investigation by concerned office
2	Giving forged Policy to customer	Insured complaints and allegations through letters and mails on faf@nic.co.in , or any other means.	Usage of portals to be blocked for agents involved in such mischief

As Motor and health are our major line of business, most of the frauds from policyholders/claimants are reported in these LOBs. Frauds in these LOB can be conducted by policyholders alone or in collusion with intermediaries like surveyors, TPA's, hospitals etc. Some of the major types of frauds conducted in these LOB are as follows

Serial No	Line Of Business	Nature of Fraud	Identification Measures/ RFIs	Mitigation/Prevention Measures
1	Motor OD	Vehicle for which theft claim has been paid, proposed subsequently for insurance	Previous claim details for the vehicle can be ascertained from IIB portal	(1)IIB portal link is built in our U/W system as a mitigation measure. (2)In case of transfer of ownership, pre inspection survey to be done.
2		Vehicle for which CTL claim has been paid, proposed subsequently for insurance.	Previous claim details for the vehicle can be ascertained from IIB portal.	(1)Guidelines issued by the company that only third party insurance to be given for vehicle for which CTL claim has been paid (2)Under special circumstances, RO alone can allow package policies to these vehicles, subject to valuation and pre-acceptance inspection by a fellow surveyor in RO panel.
3		Damaged vehicle refurbished and proposed	If the vehicle is imported, custom papers to be checked. Pre inspection survey through	(1)Special care to be taken for insuring high value imported construction

		subsequently for insurance	company's app or empanelled pre-acceptance inspection agencies issuing digital inspection reports should be done as per HO guidelines.	equipment /machineries by U/W office. (2)Similar steps to be taken for high end old vehicles. (3)Our inspection app captures Geo-Tag (Location Coordinates). (4)Similarly the inspection agencies are also carrying out digital inspection with Geo-Tagging.
4		Vehicle proposed for insurance with gap in insurance.	Pre inspection survey through company's app or through empanelled pre-acceptance inspection agencies issuing digital inspection reports should be done as per HO guidelines	(1)Vehicles with gap in insurance to be accepted only with pre inspection survey report. (2)Our inspection app captures Geo-Tag (Location Coordinates). (3)Similarly the inspection agencies are also carrying out digital inspection with Geo-Tagging.
5	Motor TP	Hit and run case being converted as accident with the insured vehicle	Collection of CCTV / newspaper and information from eyewitnesses.	Investigator to coordinate with Law Enforcement Agencies (local police) to bring out the real facts.
6		Accident involving uninsured vehicle being converted as accident with insured vehicle.	Collection of CCTV/newspaper and information from eyewitnesses.	Investigator to coordinate with law enforcement agencies (local police) to bring out the real facts.
7		Accident involving influential person vehicle converted as accident by our insured vehicle.	Collection of CCTV/newspaper and information from eyewitnesses.	Investigator to coordinate with Law Enforcement Agencies (local police) to bring out the real facts.
8		Changing of drivers.	Investigator to bring out the facts.	Coordination with Police and Court.
9		Fake policies in the market	Verification with database.	Filing F.I.R. immediately on intimation of fake policy as to avoid any future liability by taking suitable defense.
10		Exaggeration of disability	Investigator to bring out the facts.	Have the patient reexamined by medical board.
11		Exaggerated Claim Amounts	(1) Claims with relatively high proportion of pharmacy cost or physician fees. (2)Claim where cost of treatment is	(1) All TPAs have been advised to examine claims according to fraud triggers

			much higher than expected for underlying etiology. (3) High value claims from a small hospital/nursing home particularly in Class B or C cities not consistent with alimnet profile.	at various stages of claim processing. (2) Offices have been advised suitable to review the claims before payment.
12	Health	Forged Claim Documents	(1) Claims with visible tempering of documents. (2) Overwriting in diagnostic/treatment papers. (3) Same handwriting and flow in all documents from first prescription to admission to discharge.	(3) Health Audit Teams of concerned ROs are also examining claims while conducting post payment audits.
13		Fake Hospitalization	(1) Claims with apparent discrepancy in diagnosis and line of treatment (2) Claims without supporting pre/post hospitalization papers/bills (3) Claim made immediately after a policy sum Insured enhancement. (4) Claim from non-traceable person or where courier/cheque have returned from insured's documented address.	
14		Diagnosis/Surgery/Treatment specific frauds	(1) Claims with Length of Stay (LOS) far in excess of average LOS for a particular ailment. (2) Claims for medical management admission for exactly 24 hours to cover OP treatment. (3) Exaggeration of classical clinical findings to portray severity in acute medical illness/minor surgical conditions.	(1) All TPAs have been advised to examine claims according to fraud triggers at various stages of claim processing. (2) Offices have been advised suitable to review the claims before payment.
15		Multiple Claims	(1) With repeated hospitalization a) Under specific policy at different hospitals b) At one hospital for one member of family and at different hospitals for other members. (2) Multiple claims towards the end of policy. (3) close proximity of claims	(3) Health Audit Teams of concerned ROs are also examining claims while conducting post payment audits.

10. Framework for Reinsurance

Following points to be considered while entering into a reinsurance transaction with any entity:

1. In case of reinsurance entities which are not in regular business with NIC or doing business for the first time, the company needs to verify the authenticity of Reinsurance Entity and the Reinsurance transaction.
2. In case of reinsurance entities where credit rating is below benchmark or does not meet the criteria for acceptance limit, the company should verify the authenticity of reinsurer and the reinsurance transactions.
3. While transacting with direct reinsurance companies, as a precautionary measure, confirmation from reinsurers immediately after placement or premium remittance must be demanded and verified.
4. Verify the acceptance terms and risks outlined in the slip received for reinsurance placed through any intermediary.
5. Verify and confirm placement of reinsurance from the direct reinsurers, in case an intermediary is involved.
6. Robust controls, verification processes, and periodic audits shall be conducted to mitigate risks associated with reinsurance fraud.

11. Fraud Detection

Company shall identify Red Flag Indicators (RFI) for different LOBs & its activities and shall put in place appropriate control measures for each category of fraud. Company shall implement appropriate measures for monitoring and review of fraud risks, including maintaining an Incident Database of persons convicted of or attempting fraud, conducting fraud-sensitive audits for compliance with the Fraud Risk Monitoring Framework, tracking business trends from distribution channels, continuously monitoring vendor activities for compliance with fraud prevention measures and contractual obligations, and analyzing customer grievances and complaints to detect and prevent fraud.

The company shall endeavor to put in place an effective control framework for detection of frauds.

12. Preventive Mechanism

The company shall periodically run appropriate awareness campaign against frauds for all its employees, intermediaries, insurance intermediaries as well as policyholders and general public and how to prevent and protect against it.

A brief training on prevention of frauds shall be imparted to all new entrants during the induction training.

13. Escalation Mechanism for taking action

Serial No.	Type of Fraud / Fraud Committed By	Possible Mitigation Action	Authority to issue instructions/ guidelines regarding reporting of incidents of frauds to higher authorities and law enforcement agencies
1.	Agent/ Intermediary Fraud	a) Warning letters to be issued to agents. Further action to be	Regional In-Charge

	a) non-submission of premium in office by agents within 24hrs b) fake policies issued to customer by agents c) any other	taken, if repeated offences are found. b) Blocking of portal access, termination of agency license and FIR to be lodged against the agent by the Office In-Charge concerned. c) Recovery of commission in case of cancelled policies. (In all cases, where FIR is lodged, HO ERM Department to be kept informed.)	
2.	Fraud by TPAs/ Surveyors/ Brokers	For such cases, the Committee (as mentioned in the SOP to deal with intermediary frauds) may recommend for All-India De-Empanelment in terms of Surveyor Management Policy/ TPA Regulations and SLAs. Also whether, and what, further legal/criminal action to be suggested by the Committee	Since Surveyors & TPAs are IRDAI certified, the decision to inform IRDAI shall be taken by a Committee comprising of (a) DGM (Concerned Tech Deptt), (b) DGM (ERM/Anti-Fraud) and (c) Chief Compliance Officer. In case of fraud by brokers, DGM (Concerned Tech Deptt) to be replaced by DGM, Marketing in the Committee.
3.	Fake policies(other than by agents/intermediaries)	Filing F.I.R. immediately by Office In-Charge concerned on intimation of fake policy so as to avoid any future liability by taking suitable defense.	Regional In-Charge
4.	Policyholder Fraud a) Fake claim documents b) Exaggerated Bills c) Fake Hospitalization	a) Claim Repudiation b) Policy Cancellation c) Forfeiting of benefits d) Lodging of FIR by Office In-Charge concerned, depending on gravity of the case (In case of fraud by group policy member (in TGMP Policy), group client also to be informed appropriately for action against the group member and response from client to be recorded by Office In-Charge. Extreme cases requiring termination of relationship/policy, may be dealt by concerned office in consultation with HO Health Department.	Regional In-Charge.
5.	Employee Collusion is involved		Committee consisting of Deputy General Manager, HR & Personnel and Regional In-Charge (for other than HO cases) and Deputy General

			Manager of Department concerned (for HO cases)
6.	Frauds emanating at Business Office/ Regional Office (other than those mentioned above in point no 1 to 5)	On the basis of quantum of fraud or misappropriation, independent investigation shall be considered in conjunction with Legal Department (of region concerned) by the Regional In-Charge/Nodal Officer of the region concerned	Committee comprising of Regional In- Charge and 2 Regional Managers/Scale IV Officers of RO
7.	Frauds emanating at Head Office Level (other than those mentioned above point no 1 to 6)	Independent investigation shall be considered in conjunction with Legal Department HO by the concerned Department keeping the Fraud Monitoring Committee informed.	A committee comprising of DGM of the concerned Department & DGM, IT (If IT processes are involved) to issue directions for appropriate action.

14. Co-ordination with Law Enforcement Agencies

- Depending on the nature/gravity of the fraud if legal action whether civil or criminal is necessitated, required co-operation with the respective law enforcement agency i.e. police, C.B.I, C.I.D. in terms of providing details, documents, evidence etc. should be done.
- Instances, where sufficient evidence of fraud is obtained following internal investigations or reviews, shall be reported to the relevant law enforcement agencies, in consultation with the appropriate authority as mentioned in the para 13 i.e. “Escalation Mechanism for taking action”.
- Employees / Intermediaries shall cooperate with law enforcement agency and/or court for final disposal of fraud cases.

15. Framework for Exchange of Information

- A dedicated email ID (faf@nic.co.in) is shared on the website, which acts as a platform for reporting of fraud/ allegations by outsiders. These allegations are further investigated through the respective operating offices to establish them as fraud.
- Monthly Fraud Report concerning health portfolio is obtained from TPA’s in a specific format.
- All types of established fraud cases (other than internal frauds) are uploaded on GI council Fraud Risk Mitigation Portal (FRMP) for industry level sharing of information.
- A real time fraud risk management system of the company shall be in place at the time of underwriting of proposals.
- The company shall share to Insurance Information Bureau (IIB) the details of distribution channels, hospitals, third party vendors and fraud perpetrators blacklisted and IIB shall maintain the caution repository concerning all such details in order to safeguard the integrity of the insurance sector by preventing the involvement of those with a record of fraudulent activities.

16. Due Diligence

- At the time of empanelment of the respective intermediary/ service provider/outside agencies such as individual agent/corporate agent/TPA’s/Brokers/MISP/Hospital /Garage owners /Surveyor /Advocate /Investigator/ Valuers, the relevant guidelines regarding their appointment/agreement as laid down by the company amended from time to time as well as relevant regulatory body provisions amended thereto should be adhered with.

- b) The respective departments shall conduct thorough due diligence at the time of appointing employees and salespersons.

17. Regular Communication Channels

- a) The policy recognizes that proper awareness is the main pillar of fraud prevention effort. The company should aim at continuously educating its employees, policy holders, customers and general public on fraud prevention, and enlist support and participation in fraud prevention.
- b) This Anti-Fraud Policy document shall be published on the website of the company.
- c) Customers and public should be sensitized by means of advertisements detailed do's and don'ts published on website, or in posters and leaflets, or other communications sent along with policies/renewal notices etc.
- d) Employees should be targeted by means of training programs (either special training sessions or by inclusion in induction training modules). Regular circulars, newsletters etc. are also to be resorted to.

18. Whistle Blower Policy

The company has a well-defined “Whistle Blower Policy” and mechanism in place, as one of the measures of mitigation of Fraud.

19. Compliance

- a) Each employee working in the Company and every individual/organization/entity dealing with the Company shall endeavor in every possible manner to the norms laid down in this policy. Non-compliance shall be deemed violation of terms and conditions of employment/engagement or terms and conditions of contract (as the case may be) and shall be dealt with as per the Company's disciplinary procedures/terms of engagement or terms of the particular contract(s) or the law as applicable and appropriate.
- b) All employees/officers are responsible to bring to notice of their supervising officers/management about any fraud detected as soon as it comes to their notice. It is the responsibility of officers to ensure that in respect of their areas of responsibility, all reasonable and necessary steps are taken for prevention of fraud and in case of suspicion of commission of a fraud or detection of an actual fraud.
- c) This Policy and its relevant provisions shall be adequately publicized and made known to all concerned including employees, agents, intermediaries and other channel partners. All vendors, intermediaries and others dealing with the Company shall adhere to this Policy. Failure to adhere to this Policy may result in appropriate actions as prescribed under this Policy including but not limited to termination of relationship.

20. Recovery of Fraud Losses

Upon detection of fraud, the operating units or departments concerned should make all possible efforts to recover the loss amount involved. Loss mitigation action will include recovery from concerned employee/customer/policy holder/outsider and would include initiating legal action including filing of recovery suits wherever feasible.

21. Custodian of the Policy

The Chief Risk Officer (CRO) of the Company shall be the custodian of the Policy.

22. Report to the Authority

The statistics on various fraudulent cases which come to light and action taken thereon shall be filed in the prescribed forms FMR 1 providing details of (a) outstanding fraud cases and (b) closed fraud cases every year within 30 days of the close of the financial year.

23. Annual Fraud Risk Assessment

An annual Fraud Risk Assessment may be done to ascertain the extent of frauds in the organization, its overall impact, efficacy of the control mechanisms in place and the efficacy of the mitigation efforts. This shall be prepared by the ERM Department and reviewed by the FMC/ High Level Committee before being placed before the RMC.

A format has been developed for this purpose covering all the five type of fraud classified by IRDAI. (Annexure A)

The Rating Score have been given in (Annexure B)

Both these annexures dealt/part of the Anti-Fraud Policy.

24. Review of the Policy

Regular review and refinement: The components of Anti-Fraud management and associated measures, especially the effectiveness of internal controls, must be reviewed on regular basis.

This corporate Anti- Fraud Policy shall be reviewed regularly, at least annually, by the Risk Management Committee of the Board of Directors of the Company. The committee may, if felt necessary, direct the ERM department to modify any portion of the Policy suitably or consider the suggestion(s) submitted by the ERM department for modifications to the Policy during such review.

-----*****-----

Comprehensive Annual Fraud Risk Assessment Framework, 2026

[illegible]

NIC Fraud Risk Assessment Framework: Rating Scales

Occurrence/Probability Frequency of each risk

Score	Scale	Interpretation	Probability
25	(Almost) certain	We are bound to experience further incidents of this nature - in fact they are probably occurring right now!	More than 45% and above chance of occurring
20	Possible	It is distinctly possible that we will experience incidents of this nature	15% to 45% chance of occurring
15	Probable	We are likely to experience incidents of this nature before long.	11% to 15% chance of occurring
10	Unlikely	Incidents of this nature are uncommon but there is a genuine chance that we may experience them at some future point	6% to 10% chance of occurring
5	Rare	Although they are conceivable, we will probably never experience incidents of this nature	Less than 5% chance of occurring

Post classification of the sub classes of fraud risks and the sources of risks the Departments/ LOBs will define the frequency of occurrence of each fraud within the sub class based on the periodicity of risk occurring within the business activity. Occurrence frequency of each fraud risk can be classified as per the below mentioned legend. (“Rare” having least probability to occur and “Almost Certain” having highest probability to occur).

IMPACT SCALE

Score	Scale	Interpretation	Financial loss	Reputational loss
25	Extreme	Risk of severe financial strain that will impact survivability	Financial loss above Rs. 250 Cr.	1. Sustained Adverse Media coverage 2. Achievement of business objectives across LOBs unlikely 3. Severe regulatory action/ fine
20	Major	Severe loss of Enterprise capability, highly damaging and extremely costly but survivable	Financial loss between Rs. 100 Cr. & Rs. 250 Cr.	1. National media coverage resulting in client attrition 2. Achievement of Business Objectives looks unlikely 3. Regulatory action looks imminent
15	Moderate	Substantial Enterprise impact, very costly	Financial loss between Rs. 10 Cr. & Rs. 100 Cr.	1. Local media coverage, impact on select clients 2. Achievement of Business Objectives on course, but shall be impacted 3. Regulatory Action likely

10	Minor	Noticeable but limited Enterprise impact, some costs	Financial loss between 1 Crore to Rs. 10 Crore	1. Media coverage not likely to generate negative publicity 2. Achievement of Business Objectives on course 3. No regulatory action likely
5	Insignificant	Minimal if any Enterprise impact, negligible costs	Financial loss upto Rs. 1 Crore	No significant impact on business/ operations.

The inherent fraud risk is arrived by multiplying the frequency and severity of each fraud sub class. As a result there is a combination of results available which is further categorized based on the overall inherent fraud risk score as under

Overall inherent risk rating

Probability	Severity	Inherent Risk	
25	25	625	Extreme
20	25	500	
25	20	500	
20	20	400	Very High
15	25	375	
25	15	375	
15	20	300	
20	15	300	
10	25	250	High
25	10	250	
15	15	225	
10	20	200	
20	10	200	
10	15	150	Minor
15	10	150	
25	5	125	
10	10	100	
20	5	100	
15	5	75	Insignificant
10	5	50	
5	5	25	

Assessment of Controls

Control effectiveness will allow the LOBs to reconsider their priority keeping the existing control environment in mind. For the fraud sub classes with extreme and severe, control measures need to review immediately to mitigate the fraud risk. Based on this if the LOBs/ Departments feel that the controls are adequate (where there are no gaps and where the control rating is “Effective”), the LOBs/ Departments should consider recalibrating the sub class risk categorization.

Key steps in the evaluation of control step are

1. Measurement of existing mitigation effectiveness.
2. Assessment of control for each of the identified fraud sub class will be based on the following parameters:

The controls would be rated on a five point scale as shown below; Controls for each sub class are identified and assessed in a similar manner used in Inherent Fraud Risks. The controls are assessed on two parameters:

Design effectiveness – whether the control design is effective in mitigating the fraud risk

Operating effectiveness – whether the particular control is operating as expected

Design effectiveness:

All controls should be evaluated on the below given parameters for the assessment of design effectiveness:

Category	Score for parameter	Documentation
Well controlled	25	Approved Policy and business process for all processes and IT control functions independently based on rules and logics defined to prevent risks
Satisfactory	20	Approved Policy and business processes for significant set of processes and controls are IT driven which prevents future risks from occurring
Moderate	15	Approved Policy and business processes for all critical processes. Control is IT driven and provides exceptions for decision making
Poor	10	Policy or business processes defined on ad hoc basis but control is completely manual
No control/ Very Poor	5	No Policy or business processes defined. No control in place or control is ad hoc

Operating Effectiveness

The assessment of the operating effectiveness of the existing controls should be done leveraging the existing testing framework applicable in the company. Essentially, internal audit, compliance, fraud or other audit department comments on the operating effectiveness of controls should be used. The controls score would be rated based on the number of times control lapses appear in the Internal/Concurrent Audit report.

The operating effectiveness of controls would be rated on a five point scale as shown below,

Category	Score for each parameter	Description
Well controlled	25	No control failures observed
Satisfactory	20	Infrequent control failures observed compared to the frequency of control activity
Moderate	15	Limited control failures observed compared to the frequency of control activity
Poor	10	Control failures observed at a lesser frequency of the control activity
No control/ Very Poor	5	Control failures observed at the same frequency of the control activity

The overall control effectiveness is a multiplication of Control Design and Control Operating Effectiveness i.e. manual/IT score (control design) x control operating effectiveness = operating effectiveness of control. Based on the above exercise, the risk owner will finalize the risk assessment matrix for a specific business activity or a function.

Residual fraud risk and overall Risk Profiling:

Risk measurement based on risk control assessment, also known as risk profile, involves assessing the residual risk impact for each risk, process and business unit. Residual Risk is the risk that is not sufficiently eliminated after considering the control mechanisms or mitigating characteristics of the existing control. The residual risk score would be derived by dividing the Inherent Risk Score (IR) with Overall Control Score (C). This score can be aggregated at a process/ business/ company level for the purpose of monitoring.

Residual Risk (IR/C)	Interpretation
0 – 1	Well controlled
1 – 5	Satisfactory
5 – 10	Moderate
10 – 25	High